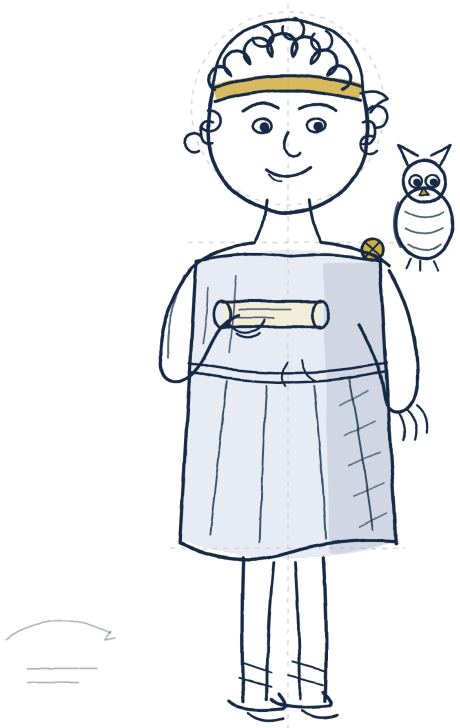
TMach for Developers

A small book about a Racket-first, self-hosted team AI platform



IoTone, Inc.

September 2026 — version 0.3.0

Telemachus, a concept sketch: a young Ithacan with a scroll, Mentor's owl on his shoulder.



How to read this

TMach — the project began as Telemachus, and the longer name survives in the repository and the environment variables — is a self-hosted platform for a team's AI tools and applications. This book is for a developer who has cloned the repository and wants to understand how it is built before changing it. It is short on purpose: the generated reference under `docs/reference/` documents every tool, workflow, permission and HTTP route from the source of truth, and the design documents under `docs/design/` record why each subsystem is shaped as it is. This book is the connective tissue between them — the ideas that recur, the decisions that were expensive to learn, and the map you need before the code makes sense.

Each chapter ends with a short list of the files to open. Read the first four chapters in order; after that, go where your task takes you.



Contents

1 What TMach is **5**

1.1 The one-paragraph version . . . 5
1.2 Tenets . . . 5
1.3 What is where . . . 6

2 Getting it running **7**

2.1 The toolchain . . . 7
2.2 Environment . . . 7
2.3 First run . . . 8
2.4 Files to open . . . 8

3 A map of the code **9**

3.1 Layers . . . 9
3.2 The four small libraries . . . 10
3.3 One principal, one check . . . 10
3.4 Files to open . . . 10

4 The authorization model **11**

4.1 Permissions and roles . . . 11
4.2 `can?`, in order . . . 11
4.3 Capabilities . . . 12
4.4 Multi-tenancy . . . 12
4.5 Files to open . . . 12

5 Data and migrations **13**

5.1 Files to open . . . 13

6 The document repository **14**
6.1 Objects, versions, blobs . . . 14
6.2 The S3 endpoint . . . 14
6.3 Sharing and provenance . . . 14
6.4 Files to open . . . 15

7 Tools and the agent **16**
7.1 Declaring a tool . . . 16
7.2 The registry . . . 16
7.3 The model seam . . . 17
7.4 What a message may carry . . . 17
7.5 Files to open . . . 17

8 Workflows **18**
8.1 The spec is the contract . . . 18
8.2 Execution is a reducer . . . 18
8.3 Files to open . . . 19

9 The document pipeline **20**
9.1 The first-user path . . . 20
9.2 Refuse, do not flag . . . 20
9.3 Templates . . . 20
9.4 Forms somebody else wrote . . . 21
9.5 Which kind of document is this . . . 21
9.6 Triggers . . . 22
9.7 Files to open . . . 22

10 Localization **23**
10.1 Three homes . . . 23
10.2 The Localization Manager . . . 23
10.3 Whose clock it is . . . 23
10.4 Files to open . . . 24

11 The knowledge graph, and retrieval **25**
11.1 Retrieval . . . 25
11.2 Asking the documentation . . . 27
11.3 Files to open . . . 27

12 The route table and the generated reference **28**

12.1 Declared, not enacted . . . 28

12.2 Generated and gated . . . 29

12.3 Files to open . . . 29

13 The job queue **30**

13.1 What a job is . . . 30

13.2 Claiming one . . . 30

13.3 When a worker dies . . . 30

13.4 Executors that come to the work . . . 31

13.5 Which model runs what . . . 31

13.6 Files to open . . . 31

14 Secrets and the front door **32**

14.1 Who may call at all . . . 32

14.2 What is hashed, and what cannot be . . . 32

14.3 Sealing the rest . . . 33

14.4 The second factor, and the way back in . . . 33

14.5 How long a session lasts . . . 33

14.6 The console's policy . . . 34

14.7 What the model is not told . . . 35

14.8 Files to open . . . 36

15 Extending TMach **37**

15.1 Four seams, and one prefix . . . 37

15.2 Where plugins are found, and what happens when one is not . . . 37

15.3 Screens of your own . . . 38

15.4 Wearing the customer's colours . . . 38

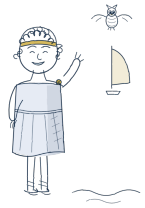
15.5 What is not available . . . 39

15.6 Files to open . . . 39

16 How the project tests **40**

17 Operating notes **42**

18 Contributing **43**



Chapter 1

What TMach is

1.1 The one-paragraph version

A team uploads its documents, talks to a model about them, runs workflows over them, shares the results with exactly the people who should see them, and does all of it on a machine the team controls. The platform is a single Racket program with an HTTP API, a browser console, an S3-compatible endpoint, a workflow engine, a scheduler, a quota ledger, and a plugin system. Every feature above the substrate — localization, the document pipeline, the knowledge graph — is built out of the substrate's own primitives, which is both the architecture and the proof that the architecture works.

1.2 Tenets

These are not slogans; each one has changed a design at least once.

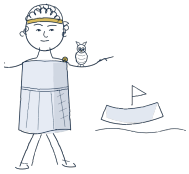
- **Clean MIT, pure open source.** No open core, no held-back tier. Concepts may be reused from the earlier Python system, but only owner-authored Racket and owner-authored documents were carried over.
- **Racket first.** The reference implementation is Racket 9.3 CS. Non-Racket plugin authoring is explicitly not a requirement; where a data format is the contract (workflow specs, tool schemas), it is because the format earns its place, not because Racket is a barrier.
- **Deterministic dependencies.** Nix is the toolchain, and there is no second one. No Homebrew, no conda, no "python spice kitchen" on the deploy host. Both of this tenet's original examples have since been decided, in opposite directions, which is what it is for: a PDF renderer *was* needed, so three arrived, pinned, each found at the moment it is called so a box without one still boots — and the marginal cost of the second was 173 MB rather than the 1.5 GB its own dependency graph advertises, because the first had already brought the font stack. A graph-visualization library is still declined: the one picture this platform draws is forty lines of arithmetic emitting inline vector graphics, which also makes it deterministic enough for a test to pin a node by name.
- **Contract first, backends swappable.** The durable product is the SDK contract, the HTTP API, the security model and the protocols. A second implementation would target

those, not the Racket code. The generated reference exists so that the contract is written down by the code itself.

- **Self-hosted and privacy-first.** Bytes never leave the instance unless the operator points the model URL at something external. The blob store is content-addressed inside an org's namespace precisely so that two tenants can never learn about each other's files.
- **Refuse rather than flag.** A wrong result that looks finished is worse than a failed step. The localization drafter, the field extractor and the knowledge-graph extractor all refuse a model reply that does not validate. This shows up so often that it has its own chapter section.

1.3 What is where

```
docs/design/        design documents and the decision log
docs/reference/     GENERATED: tools, workflows, permissions, API, plugins, SDK
docs/ops/           operator runbooks
docs/integrators-guide.md  putting your own product on the platform
docs/book/          this book
refimpl/racketmaximus/
  server/main.rkt   the HTTP server: handlers, boot, plugin loading
  server/routes.rkt the declared route table
  domain/           the model: authz, repo, flow, sched, quota, i18n, kg, ...
  pkgs/             db-kit, web-kit, cli-kit, sha2-kit: libraries with no platform
    knowledge
  plugins/          shipped plugins: doc-indexer, doc-pipeline, knowledge-graph, rs3,
    ...
  cli/              telemachus-localize, telemachus-docs, telemachus-worker,
                    telemachus-secrets
  static/           the console (one HTML file) and its English strings
  locales/          the catalogs: en, ja, nl, es-419
  test/             unit suites, smoke scripts, the e2e gate, mock servers
```



Chapter 2

Getting it running

2.1 The toolchain

```
nix develop                          # from the repo root; pins Racket 9.3, exports
    PLTCOLLECTS
cd refimpl/racketmaximus
raco make server/main.rkt            # precompile; startup is slow otherwise
raco test test/*-tests.rkt           # the unit suite
racket server/main.rkt               # http://127.0.0.1:8835
```

Enter the shell from the repository root, not from inside `refimpl/racketmaximus`: the shell hook builds `PLTCOLLECTS` from the current directory, and entering it one level down doubles the path and breaks every `db-kit` import with "collection not found".

Never run `raco test test/*.rkt`. The glob includes `test/mock-*.rkt`, which are mock servers that block forever. The unit suite is `test/*-tests.rkt`.

2.2 Environment

```
DATABASE_URL=sqlite:///$PWD/data/telemachus.db   # or postgres://user:pass@host:port/
    db
TMACH_MODEL_URL=http://127.0.0.1:11434/v1/chat/completions   # any OpenAI-compatible
    endpoint
TMACH_MODEL=qwen2.5:7b
TMACH_HOME=login          # or ‘beta‘ to serve the onboarding funnel at /
TMACH_S3_PORT=8836        # turns on the S3 endpoint, a second listener
TMACH_MULTITENANT=1       # several companies on one instance
PORT=8835
```

Each of these used to be spelled `TELEMACHUS_*`, and that spelling still answers: the platform reads the new name first and falls back to the old one, with no deadline and nothing to migrate. A deployment written against the old names keeps working untouched. `docs/ops/configuration.md` lists every variable the platform reads.

Without `TMACH_MODEL_URL` the platform runs a simulated model that echoes its input in upper case. Chat works, the smoke suites work, and nothing that needs real inference does. The tools that need a model — the localization drafter, the document pipeline, the knowledge-graph extractor — refuse to run rather than fail every validation with a misleading message.

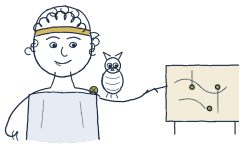
This is deliberate: an operator needs to read “no model configured”, not “the reply was not JSON”.

2.3 First run

`POST /api/bootstrap` with a username and password creates the operator, the first organization and the first team, and returns the operator’s token. It works exactly once. After that, sign in at `/` or with `POST /api/login`.

2.4 Files to open

`CLAUDE.md` at the repository root is the working notebook: every gotcha that cost an afternoon is written there, by subsystem. `flake.nix` is the toolchain. `refimpl/racketmaximus/config.rkt` is the environment.



Chapter 3

A map of the code

3.1 Layers

The server is one module, `server/main.rkt`, and it is deliberately thin: it parses requests, resolves the principal, calls into `domain/`, and encodes the response. Everything that could be wrong about the product lives in `domain/`, which knows nothing about HTTP and is what the unit suites exercise directly.

Module	Owns
`domain/authz`	principals, roles, the permission catalog, `can?`, grants, tokens, audit
`domain/db`	migrations, applied at startup, dialect-neutral
`domain/repo`	the document repository: objects, versions, blobs, sharing, provenance, triggers, the pipeline tools
`domain/flow`	the workflow engine: spec validation, bindings, the run reducer
`domain/sched`	the job scheduler and the concurrency governor
`domain/quota`	the usage ledger and limits
`domain/agent`	the tool registry, the agent loop, the plugin loader
`domain/ai`	the model executor: one call, or a stream, or the simulated fallback
`domain/i18n`	catalogs, ICU formatting, the lint, the Localization Manager
`domain/kg`	the knowledge graph
`domain/apps`	search, translation — applications composed from the rest
`domain/orgs`	multi-tenancy: organizations above teams
`domain/beta`	the onboarding funnel

3.2 The four small libraries

`pkgs/` holds code that knows nothing about TMach and could be lifted out.

`db-kit/portable` is a drop-in for Racket's `db` that rewrites `?` placeholders to `$n` on PostgreSQL. Always require it instead of `db`. Forgetting is invisible on SQLite and fails on PostgreSQL with `syntax error at or near "AND"` — and test files issue raw SQL too, so the rule applies to them.

`web-kit` wraps Racket's `web-server` for the JSON control plane and adds `web-kit/http1`, an HTTP/1.1 listener that treats request bodies as ports. The second exists because the S3 endpoint moves multi-gigabyte files and because `Expect: 100-continue` has to be answered lazily, on the first read of the body, so that a handler refusing before it reads never receives the bytes at all.

`cli-kit` is argument parsing for the command-line tools, and an EXIT CONTRACT. A tool could say "it worked" and "it broke"; it had no way to say the domain *refused* the input, which is a different answer needing a different response — fix the input, versus page an operator. Four outcomes now: `0` ran, with the result on stdout; `2` refused, with an error object that always carries reasons; `1` could not run, with stdout *empty*; `64` CLI misuse, on stderr. Two of those are enforced rather than documented: a refusal with no reasons is rejected (it is a 1 wearing a 2's exit code), and a run that did not happen writes nothing to stdout, because it must not hand anyone a document.

`sha2-kit` is SHA-256 and HMAC-SHA-256 over libcrypto. It is a package rather than a module inside `domain/` because it has no platform knowledge, and separate from `crypto.rkt` — whose contract is "no native dependencies" — because it takes the FFI. Correctness is pinned to the NIST vectors: the risk in a binding is a wrong signature, and a vector says so at once.

3.3 One principal, one check

Every request resolves to a *principal*: a user id, a team id, an operator flag, an optional org role, and — for API tokens and S3 keys — a scope list that caps what the issuer could do. Every authorization decision in the platform is one function, `can?`, described in the next chapter. Handlers call `require-perm`; a refusal raises, and the server turns it into a localized 403.

3.4 Files to open

`server/main.rkt` (skim the requires and the `HANDLERS` table), `domain/authz/authz.rkt`, `pkgs/db-kit/portable.rkt`.



Chapter 4

The authorization model

4.1 Permissions and roles

A permission is a string `resource:action`. A role is a named set of them; the built-in team roles are owner, admin, member and viewer, and two org roles sit above them. Wildcards exist (`files:*`, `*:read`, `*:*`) but two tiers are unreachable from any team role whatever it grants: `instance:*` belongs to the operator alone, and `org:*` to a company's org role alone. Every permission carries a one-line description beside its declaration; a built-in role that grants an undescribed permission fails at load. The generated `permissions.md` shows the catalog and the role matrix.

4.2 `can?`, in order

1. **The org gate.** If the resource belongs to another organization, deny, unconditionally, before anything else is consulted. This is what makes multi-tenancy sound: no share, no grant, no scope can tunnel across companies, because the check that would honour them never runs.

2. **The tier.** An `instance:` permission needs the operator flag; an `org:` permission needs the org role.

3. **The role, or a grant.** The principal's team role must cover the permission — *or* the principal must hold a resource grant naming it on this resource. A grant is a delegation: sharing an editable document with a viewer means the viewer can edit that one document, and handing a member the `manage` capability means they can share it onward. Before the sharing work, a grant only widened reachability and could not confer a permission the role lacked, which made "share for editing" a lie.

4. **Owner-ok.** The owner of a resource holds every team-tier permission on it. A member who could not delete a colleague's document can delete their own.

5. **Scopes.** An API token or S3 key caps its issuer: the scope list must also cover the permission. Scopes narrow; they never widen.

6. **Reachability.** A private resource is reachable by its owner, the operator, or a grantee; a team-visible one by anyone in the team; a shared one by owner and grantees.

4.3 Capabilities

A person sharing a document does not pick permission strings. They pick a capability — view, edit or manage — and the platform writes the corresponding set of grant rows: `files:read`; plus `files:write`; plus `files:delete` and `files:manage`. Never a wildcard; a grant row says exactly what it says. Only manage can share onward. A grant may name a user or a team in the same organization, may carry an expiry (epoch seconds — `BIGINT`, because a 32-bit column overflowed on a year-2099 expiry in the PostgreSQL smoke), and an expired row is ignored, not deleted, because it is the audit trail of who was given what.

4.4 Multi-tenancy

Off by default. With the flag on, an *org* sits above teams, a superadmin runs the instance and an org admin runs one company. The org admin manages but does not read: no `documents:read`, no `chat:use`. A company admin who needs a team's data joins that team as a member, and the join is audited. The gate at step 0 never reads the feature flag, so turning the flag off on a populated instance hides the management planes and keeps enforcing.

4.5 Files to open

`domain/authz/permissions.rkt`, `domain/authz/authz.rkt` (read `can?` and `has-grant?`), `docs/design/rbac-and-teams.md`, `docs/design/document-sharing.md`, `test/authz-tests.rkt`, `test/tenancy-tests.rkt`.



Chapter 5

Data and migrations

Migrations live in `domain/db/migrations.rkt` as a list applied at startup. Every statement must be dialect-neutral: SQLite now, PostgreSQL as the second target, and the unit suite and both smoke suites honour a pre-set `DATABASE_URL` so that everything runs against either. Verify on PostgreSQL before calling anything done; this book's authors did, and it caught an int4 overflow, a missing placeholder rewrite and a timestamp format that broke every S3 listing.

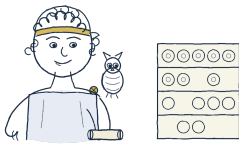
Some rules that came from those runs:

- Quote reserved words (`"window"`).
- Time windows are epoch integer columns, not timestamp arithmetic. `CURRENT_TIMESTAMP` has second resolution and its text form differs by dialect; anything that must order "newest first" within a second carries an epoch column of its own. The audit log learned this late: it ordered by its text timestamp and then by a random UUID, so two entries written in the same second came back in an order unrelated to what happened — a review decision could read before the assessment that caused it. Note what was *not* enough: milliseconds. A burst of writes lands inside one tick whatever the unit, so the column is microseconds AND the writer bumps it to stay strictly increasing within the process. A clock reading is not an ordering key.
- Use `ON CONFLICT ... DO NOTHING` or `DO UPDATE` for upserts; both dialects support the syntax with a named conflict target.
- A `hasheq`'s iteration order is not stable across Racket processes. Never depend on it for anything that must be reproducible — JSON written to disk, the order of columns in a generated table.

Unit fixtures come from `test/db-fixture.rkt`: `(fresh-db)` gives a migrated, isolated database — in memory on SQLite, a private schema per fixture on PostgreSQL, because test files run concurrently.

5.1 Files to open

`domain/db/migrations.rkt`, `test/db-fixture.rkt`.



Chapter 6

The document repository

6.1 Objects, versions, blobs

A repository object is an ownable resource with the same three fields notes carry — team, owner, visibility — so `can?` governs it with no new authorization code. Writing the same key twice appends a version rather than replacing one; the object id is the stable thing a grant or a URL points at. Bytes live in a content-addressed store keyed by SHA-256, namespaced by *organization*: global deduplication across tenants would be an existence oracle. The store is never handed a principal — only a namespace and a digest — so a storage backend has no authorization to get wrong.

Uploads are a raw `PUT` body, never base64 in JSON. Every download is served as an attachment with `nosniff` and a denying CSP unless the type is on a short inline allowlist; SVG and HTML are never inline, because they share an origin with the console.

6.2 The S3 endpoint

A second listener speaks enough S3 that `aws`, `rclone`, `boto3` and Cyberduck work: SigV4 verified from the specification and pinned to AWS's published vectors, path-style buckets named by team slug, ranged GETs (mandatory — the CLI downloads large objects in parallel ranges), multipart uploads. Access keys are ordinary credentials with scopes; the secret is stored in the clear because SigV4 needs it to verify. Unimplemented sub-resources answer 501, never a silent success. Presigned links are signed with the caller's own newest key, so revoking the key kills the link.

6.3 Sharing and provenance

Sharing is the capability model of the previous chapter, over the grants table that already existed. Provenance is `repo_derivations`: when a workflow writes a document *from* another, the output takes the source's visibility and live grants at the moment of creation — private from its first byte if the source is — and a derivation row names the source version, the run and the step. After that the two documents are independent. "Where did this form come from" is a click.

6.4 Files to open

`domain/repo/repo.rkt`, `domain/repo/blobs.rkt`, `plugins/rs3/`, `domain/s3/sigv4.rkt`, `docs/design/document-repository.md`, `test/repo-tests.rkt`, `test/s3-smoke.sh`.



Chapter 7

Tools and the agent

7.1 Declaring a tool

```
(define-tool doc_text
  #:description "Return the text of a repository document."
  (object string #:description "The repository object id")
  (version string #:optional #:description "A specific version id"))

(register-tool! "doc_text" doc_text "files:read"
                (lambda (conn principal args) ...))
```

`define-tool` expands to the OpenAI-compatible function schema the model sees, so the declaration and the contract are one thing. The handler gets the database connection, the calling principal and the parsed arguments; it checks its own permission and meters its own AI spend. A result that is not a string is JSON-encoded at the agent boundary and kept as a value inside a workflow — a list-returning tool feeds a `map` step directly.

7.2 The registry

Built-in tools, plugin tools and workflow tools all land in one registry, tagged with their source. A team may disable any tool; the agent offers only enabled tools to the model and dispatch refuses disabled ones. Plugins run in-process with platform privileges — placing one in `plugins/` is the consent — and sandboxed out-of-process plugins exist as a separate, capability-scoped mechanism, speaking newline-delimited JSON over stdio.

An out-of-process tool may answer with STRUCTURE, not only text: its result message carries an optional structured field beside the human one. Without it every such answer became a JSON *string* by the time a workflow bound it, so a later step needed an in-process shim whose whole job was to parse what the platform had just stringified — while an in-process tool had been free to return a value for slices. The platform never guesses that a string was meant to be JSON; the plugin says so by sending the structured field.

7.3 The model seam

Everything that calls a model goes through `run-chat` in `domain/ai/executor.rkt`, and the tools that need structured output take the model as a parameter (`current-doc-chat`). Unit tests script it; the HTTP smokes run `test/mock-llm.rkt`, a deterministic OpenAI-compatible server whose chat mode answers from a file of `needle: reply` pairs, longest needle winning. The same smoke runs against a live model when the model URL is set. This is how a pipeline that needs a model is tested in CI in seconds and verified against qwen2.5:7b on a developer's machine.

7.4 What a message may carry

A message's content is a string *or* a list of parts, the OpenAI-compatible `[{type: "text", text: ...}]` shape that gateways and multimodal servers send. One module decides this for every path — the agent loop, the chat endpoint, the stream and the pull wire — so they cannot disagree. Text parts are joined; content that carries parts and *no* text is a named error rather than a quiet empty string. That distinction is the whole point: an empty reply must never be manufactured, because it is indistinguishable from a model that said nothing. Content that is absent or empty is still legitimately empty — that is what a tool-call-only turn looks like — so the agent parsers raise only when the turn has no tool calls either. This was a silent bug for months: `(if (string? c) c "")` read every reply, and a provider that answered in parts produced an empty message and no complaint.

A caller may also ask for a shape. `response_format` — `text`, `json_object` or `json_schema` — rides to the provider *and* is checked against the reply here, because most local servers ignore the field entirely and a schema request would otherwise come back as prose the caller parses as though it had conformed. Validation is the same subset validator, and the same `$.total: expected number, got string` refusal, as the document pipeline's extraction. The simulated no-model fallback refuses a format rather than passing an upper-cased echo off as conforming JSON. Streaming judges the format once the stream has ended and reports the verdict in its final event; raising after the answer has already gone out would be worse.

7.5 Files to open

`domain/tools/dsl.rkt`, `domain/agent/registry.rkt`, `domain/agent/plugins.rkt`, `domain/ai/executor.rkt`, `docs/reference/tools.md`.



Chapter 8

Workflows

8.1 The spec is the contract

A workflow is a validated data document: a slug, typed inputs, and steps that use a tool, branch on a predicate, or fan out over a list. `define-workflow` is a macro that emits that document; a JSON document posted to the API goes through the same validator, and there is no second path. Unknown fields are rejected, including a newer spec version and a step kind this build lacks. The binding sublanguage is frozen — references and seven predicates, no arithmetic, no evaluation — and the escape hatch is "write a tool".

```
(define-workflow process-upload
  #:input ([object_id string] [schema object] [template string] [locales array])
  (step text     (tool doc_text #:object (in object_id)))
  (step fields   (tool doc_extract_fields #:text (out text result) #:schema (in
    schema)
                                          #:object (in object_id) #:run (run-id) #:
    step "fields")
                #:retry 1)
  (step has_form (choice (empty (in template)) #:then translate_source #:else form))
  (step form     (tool doc_render #:template (in template)
                                  #:data (out fields result fields) ...))
  (step translate_form (map #:over (in locales)
                            (tool doc_translate #:object (out form result object_id)
                                                #:locale (item) ...))
        #:end)
  ...)
```

8.2 Execution is a reducer

The engine keeps nothing in memory. `flow-advance!` reads a run from the database and enqueues its next step as a scheduler job; when the job finishes, the step's output is written and the cursor moves. Durability, cancellation, quota admission, per-team concurrency caps and the org gate are therefore inherited from the scheduler rather than reimplemented. A fan-out is one parent row and N child jobs; the last child to finish advances the cursor under a lock, or two children would each enqueue the next step.

Declared inputs are required and typed; a run that omits one is refused at start rather than resolving a binding to null three steps in. Plugin-contributed workflows are materialized into

a team's definitions on first lookup; that insert is idempotent because the console fires two lookups in parallel and the second once produced a 500 — found by the end-to-end gate, not by any smoke that looked things up one at a time.

8.3 Files to open

`domain/flow/spec.rkt` (normative), `domain/flow/dsl.rkt`, `domain/flow/bind.rkt`, `domain/flow/run.rkt`, `docs/design/workflow-engine.md`, `docs/reference/workflows.md`.



Chapter 9

The document pipeline

9.1 The first-user path

A team uploads a file and a workflow processes it: extract its text, pull structured fields against a JSON schema, fill a form template, translate the result. Four core tools compose into the shipped `process-upload` workflow; schema, template and locales are inputs, so one workflow serves invoices and intake forms with no new code. Every output is a repository document beside its source, with the source's grants and a provenance row.

9.2 Refuse, do not flag

The field extractor validates the model's reply against the schema and refuses a missing required field, a string where a number was asked for, and an invented key — an object schema with no `additionalProperties` is *closed*, a deliberate departure from JSON Schema's default. The template renderer refuses a placeholder the data cannot satisfy rather than rendering a blank: a form with an empty Total that looks finished is the failure the whole design exists to prevent. The step retries once, because a schema mismatch is the model's mistake and a second reading at temperature zero often conforms.

9.3 Templates

Markdown and HTML templates use `{{field}}`, dotted paths and `{{#each items}}` blocks. A DOCX template is a zip whose `word/document.xml` carries the same placeholders, and two things make that harder than it sounds: Word splits a placeholder across runs the moment the author pauses or the spell-checker looks at it, so every tag between a `{{` and its `}}` is dropped before rendering; and line items want a table row per item, so a row whose only text is `{{#each items}}` opens a block and a row that is only `{{/each}}` closes it. **PDF rendering was deferred here and is not any more** — three engines, each for the half it is good at, and all three found at the moment they are called, so a box without one boots and only that call is refused.

The default turns a filled Markdown or HTML template into a PDF through the document converter and TeX engine the book itself is built with. The second takes an HTML template and the paged-media CSS in it: running headers, a page count, and an archival profile that a conformance validator passes at 144 rules. A headless browser was the obvious alternative and

was declined on measurements rather than taste — it implements none of those CSS features, cannot emit the archival profile at all, brings a JavaScript engine to a template an operator or a customer wrote, and puts a browser in the image. What made that choice honest was measuring the *marginal* closure: the renderer's own dependency graph is 1.5 GB, of which 82 of 105 paths were already in the image because the book's toolchain had brought the font and text-shaping stack along, so the real cost is 173 MB. The standalone figure was nine times the truth.

Two things about that engine are worth carrying away. A template reaches a repository document by object id and each reference is read *as the caller*, then inlined, so every other protocol can be switched off — a template that could reach any object by id would be a way past the repository's own gate. And the exit code is not the verdict: a resource it could not load is logged as an error and the process exits zero, leaving a hole where the logo was, so the log is parsed and a refused resource becomes a refusal that names what a template may reach.

The third engine converts a filled DOCX through an office suite, which is roughly a gigabyte and therefore *not* in the image: it is opt-in, added to the packaged path by an integrator who installed it, and the refusal says so, because "needs an office suite" with no hint where it comes from is how somebody concludes the feature is broken. Its sandbox is not a flag — the suite takes no equivalent argument — so the constraint goes on the *input*: a template that declares an external relationship, which is how a word processor stores a linked image, is refused by name before anything converts. That is checked before the binary is even looked for, which is what makes the refusal testable on a platform where the suite cannot be installed at all.

9.4 Forms somebody else wrote

Filling a template is one half; the other is an interactive PDF form that *arrived*, and it needed two binaries rather than one. The first lists and fills, because its export already names every field with its kind, value and options, so nothing has to be composed in an intermediate format. The second flattens, because the first has no flatten of any kind. A value is held to its field's kind and a choice field to its own options — a stored value the form's own reader cannot interpret renders *blank* while the document claims it was filled. And the unmatched list is computed here, because the filler exits zero on a field name no field carries: without that, a misspelled field hands back a document that looks filled with nothing saying which half was ignored. A partial match is a report; every name wrong is a refusal that lists the fields the form does have.

9.5 Which kind of document is this

Routing wants a type, and a type comes from a *chain* of backends rather than a choice of one: rules first, because they cost nothing and answer the same way every time, then the model for what no rule described. **The rules backend has no regular expressions, and the requirement asked for them** — the same reason the redaction detectors are named rather than written, with the same weapon and the same operator-authored configuration. The field-extraction tool's pattern argument is not a counter-example: that one runs against the model's reply, which this platform asked for and bounded.

A rule match *is* the confidence. "Short-circuits when it is confident" has no degrees for a deterministic rule, and 0.85 would be a number nothing computed. The answer lands in three object attributes — the type, the confidence to two fixed decimals because the metadata filter

is an equality test, and which backend decided — plus a record document beside the source, so no migration was needed. **A document this platform cannot read is still classifiable**, which is why the text is optional and why the shipped workflow classifies *before* it tries to read: a photograph or a scan refuses text extraction, correctly, so a pipeline that reads first can never reach the documents that most need routing. The first version of that workflow had it the other way round and its own test found it.

A low-confidence answer parks the run on a person, and the threshold is an ordinary branch step rather than a flag on the tool, because only a *step* can park a run — a flag would have the tool reach into the review subsystem from inside a tool call. The person's label is held to the same closed set the model's is: a free-text answer is one keystroke from "Invoice", "invoices" or a trailing space, and each of those is a type no trigger and no filter will ever match, so the refusal lists the types the run offered and says it will not guess. An approval re-records the type as decided by review at full confidence, because leaving the model's own guess would make a document somebody checked indistinguishable from one nobody looked at — and would offer it for review again on the next pass. An empty label *withdraws* the type, and the record is still written, so who withdrew it and why survives.

Two shapes fall out of that and are worth naming because each was tempting to build differently. The backlog is a **workflow**, not a batch mode of the tool: a flag would be one tool call doing unbounded work with no per-document retry, no cancellation granularity, no quota admission between documents, and a result nothing can branch on. And the evaluation harness scores *abstention* separately from error — the rules backend is designed to answer only when a rule matched, so counting silence as a mistake makes a careful rule set look worse the more careful it is, and sends an operator to loosen the rules that are carrying the load. Accuracy is over what it answered, coverage over the set, and both are needed: a backend that answers one document perfectly is 100% accurate and useless.

9.6 Triggers

A trigger is a team-scoped subscription: when a document matching this prefix and these content types lands, run that workflow with it. Triggers are evaluated in exactly one place — a hook at the end of `repo-put!`, after the version commits — which covers the console upload, the text-document shim and an S3 `PUT` by construction. A match enqueues a run as the *uploader*, scopes and all; a run can only read what its uploader could read, and its outputs are owned by someone real. Fires are exactly once per version. A pipeline's own outputs never re-fire the trigger that produced them, and an opted-in trigger never fires on the output of a run it started itself; without that rule an opted-in trigger ran itself fifty times in a test before the drain limit stopped it. An S3 key issued with the default `files:*` scopes cannot start a workflow — the trigger's history says so plainly — and needs `workflows:run` for a prefix meant to fire.

9.7 Files to open

`domain/repo/doc-tools.rkt`, `domain/tools/jsonschema.rkt`, `domain/repo/classify.rkt`, `domain/repo/htmlpdf.rkt`, `domain/repo/pdfform.rkt`, `domain/repo/docxpdf.rkt`, `domain/repo/triggers.rkt`, `plugins/doc-pipeline/main.rkt`, `docs/design/document-workflows.md`, `test/doc-pipeline-tests.rkt`, `test/doc-triggers-tests.rkt`, `test/doc-pipeline-smoke.sh`.



Chapter 10

Localization

10.1 Three homes

Server refusals live in `surface/messages.rkt`; the console's chrome in `static/ui-strings.json`; the generated documentation's prose in `docs/reference/strings.json`. All three are *surfaces* for one extractor, which folds them into `locales/en.json`, the base catalog. Translations live beside it, each string pinned to the hash of the English it was made against: editing the English makes the translation stale automatically, in every language, with nothing rewriting a status. The funnel's operator-authored copy is the exception — an overlay on the experience document, not a catalog — because it is content, not code.

Resolution is the request's locale header, then the instance default. An unknown locale falls back to the instance default, not to English; a Japanese-default instance is possible.

10.2 The Localization Manager

The flagship: the platform building a real tool out of its own primitives. Catalogs on disk stay the shipping artifact; two tables are the workflow around them. *Missing* and *stale* are derived, never stored. A translator cannot approve their own string. AI drafting is a queue of scheduler jobs, twenty strings each, quota-metered — and a bulk draft stops when the team is over budget, which looks like a hang and is the platform working. A draft that loses, invents or mangles a placeholder is refused; the check counts braces, because the formatter is lenient by design and accepts exactly the drafts that need refusing. Dutch and Latin American Spanish were produced with this tool, every string reviewed, and pass the tool's own gate.

10.3 Whose clock it is

A locale decides which words somebody reads; a timezone decides which hour they read on. They arrived separately and the second is the smaller subsystem with the sharper traps.

It is an IANA name, never a stored offset. An offset is wrong half the year in most of the world, and a schedule asks about the *future*, where only the rule can answer. The name is validated against the database on disk, like the list of available locales, so an unknown one is refused rather than quietly substituted: somebody given UTC for a typo finds out from a report that arrives at the wrong hour.

The layers do not tighten, and that is the opposite of the session policy deliberately. A person's choice wins over their company's, which wins over the instance's, which falls back to UTC — where a session timeout has the instance own the floor and a company only able to shorten it. A timeout governs what is *permitted*; a timezone governs how a number is *rendered*, and nobody is protected by being forced into the wrong clock. The report names the layer that answered.

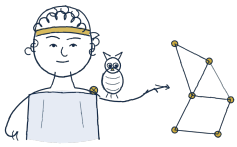
The zone database is built slim, and the footer is the normal path. A zone's transition table stops where its rule became regular — one European zone's last entry is in the 1990s — and everything after it is a compact rule string in the file's footer. A reader that walked only the table would answer today's question with a rule from thirty years ago, and a scheduler only ever asks about the future. The sign in that rule string is also inverted from the one everybody expects, which is a sixteen-hour error that still looks like a plausible time of day.

Converting a local time to an instant answers three things, not one: it worked, no such instant exists, or two do. Twice a year an hour is skipped and an hour repeats, so "07:00 local" is not always one moment, and the caller decides what to do about it — a schedule passes the skipped morning over and records why, because firing at some other time is a schedule that silently moved and inventing the instant is a lie. The implementation needs two probes either side of the day, because the offset depends on the instant while the instant is what is being solved for; a single round-trip check cannot see the repeated hour at all, and reported the second 01:30 as fine.

Stored timestamps stay UTC, all of them — the same line the funnel's translation overlay draws between presentation and data. And the container has no system zone database, so the path to one is declared in the build closure: without that, every zone resolves to UTC on every real install while working perfectly in a checkout.

10.4 Files to open

`domain/i18n/`, `cli/telemachus-localize.rkt`, `locales/`, `docs/design/localization.md`, `domain/time/zones.rkt`, `domain/time/tz-policy.rkt`, `test/timezone-tests.rkt`.



Chapter 11

The knowledge graph, and retrieval

Entities and the relations between them, extracted from the team's documents, every fact traceable to the document and version that asserted it. Nothing enters the graph without a source, and that one rule makes the rest fall out.

Visibility is inherited, never assigned. A fact is visible to a principal if at least one of its mentions is on a document they can read; mentions are filtered per row, so a private memo's snippet stays private even when the team can see the fact through a report. An entity a caller can see no mention of does not exist for them, and the API does not distinguish that from a missing id.

Validation is the provenance. The extractor asks the model for a strict shape and refuses a snippet that is not a verbatim substring of the text, a relation to an entity not in the same reply, or a nameless entity. A new version of a document supersedes its old mentions; deleting a document forgets its facts; an entity or relation with no mention left is pruned.

Deliberately narrow. Deduplication is by type and normalized name; cross-type merging is where knowledge graphs go to die. There is no graph query language — two hops from a named entity covers the questions people have — and no visualization library: the tab is lists with citations, and the agent's `kg_query` tool answers in text with the documents that said so.

11.1 Retrieval

The graph answers "what do we know about Acme". The other half of the question — "what did we read about this" — wants passages, and that is a separate stack built in six steps, each landing with its own tests before anything called it.

The chunker counts characters, not tokens, because there is no tokenizer on this side. A token count computed here is a guess wearing a measurement's clothes, so the unit is 1,024 characters with 15% overlap, which is the design's 256 tokens at roughly four English characters to the token. The offsets are the extractor's own coordinates — the same ones a page-and-bounding-box span indexes — so "cite the page this was read from" is a lookup rather than a mapping, and a mapping can disagree. A chunk is never emitted for whitespace alone: a zero vector has no direction, and not producing one costs no request and no row.

And that ratio is an English assumption, which is a finding rather than a footnote. The same book chapter is 3,342 characters in English and 2,079 in Japanese, yet Japanese runs near one token per character against English's four — so a 1,024-character Japanese chunk carries about four times the tokens the default intends, and a chunk that overruns the

model's context is truncated *by the model*, silently. The calibration that followed went against the hypothesis: over 384 to 2,048 characters at three overlaps, eighteen cells against a real embedder and this project's own documentation, recall moved 82–93% in English and 37–59% in Japanese and **no cell was preferred**. Shrinking the chunk does not close the gap, so the gap was never the chunk's. What doubled Japanese recall was changing the *model* — same questions, same corpus, 41% to 81%. The parameter was not the lever.

A vector is a sealed binary column, one row per chunk, scanned in process. No extension, no second service, no approximate index — and every one of those was measured before it was declined. SQLite's vector extension cannot be reached from this platform at all: the database binding exports no extension-loading entry point, so `load_extension` answers "not authorized" while the identical library loads it from the command line. PostgreSQL's does work unmodified, and is still declined, because a full scan is 8 ms at a thousand chunks, 74 ms at ten thousand and 759 ms at a hundred thousand, against an index that takes 272 seconds to build. The threshold to look again is written down — fifty thousand chunks for one team — and the window cap is deliberately *the same number*, so a team whose window truncates has already crossed the line where the whole approach is meant to be reconsidered.

What made sealing affordable was discovering that the seal was a string API. Packed single-precision floats through it cost 51 times what the cipher costs and 1.8 times the storage, and none of that is encryption: it is base64 in, UTF-8 out, UTF-8 in, base64 out, four whole-buffer conversions of which two inflate the value by a third. Nothing had noticed, because the largest sealed value in the schema until then was 200 KB of extracted text. At the bytes level the whole scan costs 4–14% more than unsealed, so the privacy-first default is not the slow path — which is the only reason a document vector can be sealed at all, and it must be, since embedding inversion recovers much of a chunk's source text.

Authorization is per row, after the arithmetic, over four times as many candidates as the caller asked for. A document is many chunks, so the number of permission checks is the number of distinct *documents* among the candidates, which a memo keyed by object makes cheap. The headroom is the one approximation here and it is stated rather than buried: if the ten nearest chunks all belong to a colleague's private document, the query answers nothing while a readable eleventh was a good match. Authorizing the whole window first would close it exactly and costs one query per document in the team, seconds at ten thousand documents, on a query path. So the hole is pushed out four-fold rather than closed, and a scan that exhausts its headroom *says so*.

A hit carries where to read and not the text: the store holds offsets and a vector and no prose at all. Composing the passage is the retrieval tool's job, and the tool answers structure where the graph's `kg_query` answers a sentence — both right for their reader, because the whole point of carrying offsets is that a citation be machine-readable, and flattening them into prose leaves a model retyping a key it was handed.

`?semantic=1` on search degrades; the retrieval tool refuses. A caller asking for a *search* gets the keyword half and a named reason the other did not run, because the alternative leaves somebody asking for both worse off than somebody asking for neither. A caller asking for exactly this gets the unset variable named and nothing else. One asks for a service, the other asks for a capability. It is also the first content search that survives the content-encryption switch: the keyword half is a SQL `LIKE` and is dropped on a sealed instance, where the semantic half compares vectors and unseals only the text it quotes.

11.2 Asking the documentation

The same stack, pointed at the product's own manual, is the `Docs` panel. Three decisions in it are worth carrying away.

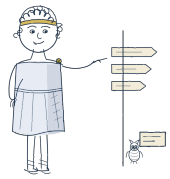
The corpus belongs to the instance, not to a team, because a document table row needs a team: the shipped manual in a team would be ingested once per team, charge each team's storage, and be offered to each team's knowledge-graph extraction.

It is ingested by an operator command and not read off disk, because the packaged build does not contain `docs/` — a boot-time read works in every developer's checkout and finds an empty directory on every real install. An unchanged file costs no model request, so a re-ingest after editing five pages costs five.

"I don't know" is two layers and neither is sufficient. A similarity floor before any model call, then every path the answer cites resolved against the passages that were actually retrieved. The floor cannot be a relevance test, and the measurement is why: a Japanese question that missed its chapter entirely still scored higher than an English question that found the right file. And the one defect only a real model found: asked something the documentation does not cover, the model refused correctly *and then named all five passages by way of explaining what they were about* — so five valid citations turned a refusal into a five-source answer. An answer that cites every passage it was shown has cited nothing, and raising the floor is not the fix, because the genuinely useful answer to a different question scored lower than that refusal did.

11.3 Files to open

`domain/kg/kg.rkt`, `domain/kg/kg-tools.rkt`, `plugins/knowledge-graph/main.rkt`, `docs/design/knowledge-graph.md`, `test/kg-tests.rkt`, `domain/ai/chunk.rkt`, `domain/ai/vectors.rkt`, `domain/ai/chunkstore.rkt`, `domain/ai/chunksearch.rkt`, `domain/repo/passages.rkt`, `domain/help/`, `cli/telemachus-help.rkt`, `docs/design/vector-store.md`, `docs/design/in-product-help.md`.



Chapter 12

The route table and the generated reference

12.1 Declared, not enacted

Every HTTP route is one entry in `server/routes.rkt`: method, path pattern, handler key, how it authenticates, the permission it enforces, the feature flag it sits behind, and one line of documentation. The server binds keys to handlers in one table and refuses to boot if either side names something the other lacks. An endpoint cannot exist undocumented, and a documented endpoint cannot fail to exist. Public-ness is declared rather than a comment beside a `cond` clause, which is what lets a test assert it.

The table is the enforcement, not a description of it, and for the first months of this codebase it was not. The three fields were documentation: each handler did its own authentication, permission and feature check by hand, and the generated reference published the declarations as fact. One route declared a permission and enforced nothing — straight from authentication to the data, so any authenticated caller could read the team's, the company's and the *instance's* retention policy, while its sibling two definitions below had the line. One forgotten line and nothing checking. The dispatcher applies all three now, and the order is load-bearing: the multi-tenancy gate first, so a single-tenant instance answers 404 rather than telling an anonymous caller which routes exist; then authentication, so a 401 precedes any mention of a permission; then the feature flag; then the permission. The handlers keep their own checks on purpose — two layers on the authorization path is a feature, and deleting ninety-three of them would make the dispatcher a single point of failure.

A permission the dispatcher may pre-check is not the same as one it may not, and the distinction is per *route* rather than per permission. The same permission on a route with a document to weigh must be left to the authorization function, which also admits the owner and anyone holding a grant — a role pre-check there would be *stricter* than the handler's own and would refuse exactly what sharing exists for. Deriving that from the permission instead of declaring it per route was the first attempt and it left the unprotected route above looking covered.

A feature flag has three layers, and the one place in this platform where absence means *enabled*: the instance, then the company, then the team, each able only to tighten. A team cannot turn on what the instance turned off, and that attempt is a refusal naming the layer rather than a stored row that resolution ignores — but turning a feature *off* is allowed at every layer, including under a layer that already says no, because that is a team recording its own

intention and it survives the layer above being switched back on. Absence means enabled so that an instance which configured nothing behaves exactly as it did before the layers existed.

And a gate that reads a declaration can only ever check one direction. A second one asks the opposite question — is every permission in the catalog enforced *somewhere* a route can reach — and it found a permission granted to three roles, described in the catalog, read by nothing, while the endpoint it was obviously for demanded the instance operator's. So a team that hit its daily token default could be unblocked only by the operator. That gate fails in both directions, so a permission that is deliberately unreachable has to be listed with a reason; a one-directional allowlist rots into a list of excuses.

12.2 Generated and gated

`telemachus-docs describe` evaluates the tool registry, the plugin loader, the workflow specs, the permission catalog and the route table into one JSON model; `render` writes `docs/reference/`; `check` regenerates and fails on a byte of difference. The output is committed, so a pull request that changes a tool's parameters shows the documentation change in the same diff. Every description is also a `doc.*` message in the catalogs, translated by the same Manager as everything else.

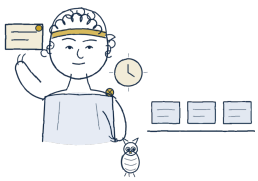
```
racket cli/telemachus-docs.rkt render      # regenerate docs/reference/
racket cli/telemachus-docs.rkt check       # the CI gate
racket cli/telemachus-docs.rkt render --locale ja
```

Adding an endpoint is therefore: one entry in the table, one handler in the map, one render, one commit. Forgetting the render fails CI; forgetting either half refuses to boot.

The same model also emits `openapi.json`, so a viewer or a client generator can read the surface. **It carries no request or response schemas and says so in its own description**, because they are declared nowhere: they are read out of the handler bodies one at a time, so emitting them is not a generation problem but a decision about where a shape should live, with every route in the table behind it. A reference that implied completeness would be worse than no reference, so the absence is stated in the document and a test pins both halves — the note must be there, and no operation may carry a body or a response. The response field is omitted entirely rather than stubbed: a fabricated "200: OK" on every operation is the generator asserting a status code it has not read, wrong for every 202, 204 and 302, and the one claim a code generator would act on.

12.3 Files to open

`server/routes.rkt`, `server/main.rkt` (the dispatcher), `cli/telemachus-docs.rkt`, `docs/reference/`, `test/route-perm-gate-tests.rkt`, `test/openapi-tests.rkt`.



Chapter 13

The job queue

13.1 What a job is

A job is a row: a team, a user, a kind, a JSON payload, a priority, a status. Nothing about a running job lives in memory, which is why a restart loses no work and why a workflow step, a bulk translation and a model call routed to another machine can all be the same thing. A bounded pool of worker threads drains the queue; each thread claims one job, runs its kind's handler, and writes the result back to the row.

Two policies are applied at claim time rather than inside the handler, so no kind can forget them: a **per-team concurrency cap**, which stops one team's batch monopolizing the pool, and **quota admission**, which leaves an over-budget team's jobs queued rather than failing them. A queue that has stopped moving with nothing running is usually a team out of AI budget, and that is the platform working.

13.2 Claiming one

Claiming looks trivial and is not. The pool scans for queued rows, picks a candidate, and flips it to running — but the flip must be *conditional* on the row still being queued, and the condition is worthless unless somebody reads the result:

```
UPDATE jobs SET status='running', started_at=CURRENT_TIMESTAMP,
               lease_until=?, executor_id=?, claim_token=?
 WHERE id = ? AND status='queued'
 RETURNING id
```

The claim is believed only when a row comes back. This matters more than it looks: the driver reports affected rows on PostgreSQL and not on SQLite, so a row count would have been a dialect-dependent answer, while `RETURNING` works on both. A claimant whose update matched nothing moves to the next candidate instead of running a job another worker holds. Before this, exclusion rested on a lock inside one process — fine until there are two.

13.3 When a worker dies

Every claim carries a **lease**: a timestamp the holder refreshes while it works. If the holder dies, the lease lapses, and a reaper returns the job to the queue with its attempt count raised,

failing it for good after three. This applies to the in-process pool exactly as it does to a remote worker; when it did not, a pool job whose process died sat `running` forever and kept consuming its team's concurrency slot. A job left behind by an older build — running, with no lease — is swept back to the queue when the pool starts.

Recovery creates a subtler problem, and it is the one worth remembering. Suppose a lease lapses while the original run is still alive; the reaper requeues the job; the *same* holder claims it again. The first run finally finishes and writes its result. Status matches. Holder matches. Nothing in either check can tell the two attempts apart. So each claim also mints a **fencing token**, and every later write about that attempt carries it — the terminal write, the lease refresh, and a remote worker's heartbeat, completion and failure. Requeueing clears the column; so does every terminal write. A token from a previous attempt can never match again, and neither can a second write from the current one.

```
claim  -> id + lease_until + claim_token
heartbeat / complete / fail  -> must carry that claim_token, or 409
```

13.4 Executors that come to the work

An inference host does not have to be callable from the server. A **pull executor** runs a loop that long-polls for a job it can run, heartbeats while it runs it, and posts the result — so it works from behind NAT or on a tailnet, connecting outward only. Its credential is an API token whose only scope is `jobs:execute`, shown once and bound to the executor row; the executor is resolved through the token, never through a field in the request.

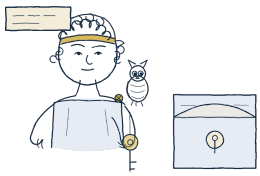
A **remote kind** is registered with no in-process handler: the pool skips it, only a worker can claim it, and its results are validated by a function the kind must supply, because there is no local handler to be strict on its behalf. The shipped one is `infer.chat` — exactly the wire `run-chat` speaks — so a synchronous model call becomes a sub-job and waits for a worker, and every model-using tool works unchanged when its chat is routed elsewhere. A sub-job carries its parent and is exempt from the team cap at claim: two parents at a cap of two would otherwise each wait forever for a sub-job nothing could claim.

13.5 Which model runs what

A *model role* resolves to an executor name: the team's setting, then an environment variable, then the local model. One role ships — `utility` — and it carries the bulk work: knowledge-graph extraction, the pipeline's field extraction and translation, and the Localization Manager's drafts. A person's chat never goes there. The tools set the role around their own model call, so a GPU box can take the batch work without any tool knowing it exists. Setting a role to an executor that does not exist is refused, because a typo would otherwise send every extraction quietly back to the local model.

13.6 Files to open

`domain/sched/scheduler.rkt` (read `claim-job!`, `finish!` and `with-lease`), `domain/exec/pull.rkt`, `domain/ai/roles.rkt`, `cli/telemachus-worker.rkt`, `docs/design/pull-executors.md`, `test/pull-tests.rkt`, `test/pull-smoke.sh`.



Chapter 14

Secrets and the front door

14.1 Who may call at all

Before any of this: a request has to become a principal, and for a long time it could become one too easily. With no bearer token, the server fell back to two HEADERS — `X-Telemachus-User` and `X-Telemachus-Team` — and resolved them to that user. On a laptop that is a convenience: a script acts as somebody without minting a token. On an instance bound to a network address it was a login, and a free one: any caller on that network was whoever they said they were, with every permission that user holds. Note where this sits — *before* role checks, scopes, the org gate and session policy, none of which run until a principal exists. An identity mistake at that layer cannot be caught by any control above it.

The headers are honoured only from a trusted peer now: loopback, or an address the operator names in `TMACH_TRUSTED_HEADER_PEERS` because a reverse proxy really does terminate there. Nothing is trusted for looking private — "10.x is internal" is an assumption about somebody else's network. `POST /api/bootstrap` is gated the same way, because an un-bootstrapped instance belongs to whoever calls it first, and on a LAN that is a stranger; an operator who cannot reach loopback presents a secret instead.

The rule lives in its own small module so it can be tested directly. That matters more than it sounds: every smoke runs on the same host as the server, so a smoke can never *be* a stranger, and this gap survived months of them.

14.2 What is hashed, and what cannot be

Passwords and API tokens are stored as hashes — a token as a peppered HMAC-SHA-256 with the pepper in the environment, so a database dump without the process's environment cannot be replayed. Rotating the pepper signs everyone out at once, which is a fine emergency action and the reason it is rotatable. Tokens also expire now: a session after thirty days, a console-issued API token after ninety, and a row with no expiry is still "never", so an upgrade signs nobody out.

Three secrets cannot be hashed, because they are not compared — they are *used*. A TOTP seed generates the code; an S3 secret keys the HMAC that verifies a signature; a push executor's key signs its requests. All three used to sit in the clear, which made one dump — a backup, a replica, a `pg_dump` pasted into a ticket, a stolen volume snapshot — enough to replay every one of them.

14.3 Sealing the rest

They are sealed with AES-256-GCM, keyed from the environment and never from the database. What this protects is deliberately narrow, and worth stating precisely because the earlier note in the code got it half right: this defends a **dump** and does nothing for a **host**. An attacker running as the server reads the key out of its own environment. But a dump travels without that environment, and a dump is the thing that ends up somewhere it should not.

```
enc:v1:<key-id>:<nonce>:<ciphertext+tag>
```

Anything without that prefix is plaintext and is read as-is, so adopting a key is not a migration and needs no downtime: rows seal as they are rewritten, and a CLI seals the rest. The same CLI rotates — a previous key reads, the current key writes — and it is deliberately not something the server does at boot, because a mistyped key at startup would seal every row with a key nobody has. Running with no key at all remains supported; that is the "the database is the trust boundary" position, and the only change is that it is now visible in the boot line and in the admin status rather than inherited silently.

Two details carry weight. Each value is sealed with its own column and row id as additional authenticated data, so a ciphertext lifted out of one row and pasted into another does not open — someone with write access cannot move a known secret onto another principal. And a sealed value that will not open *raises*: it must never degrade to an empty string, because an empty TOTP seed would silently disable somebody's second factor.

14.4 The second factor, and the way back in

A password can be changed and an access key re-issued. A TOTP seed cannot be rotated by using it, which is what made a leaked one permanent — so it is revocable: a user can turn their own off, and an operator can revoke anyone's, both audited. That covers the leak. It does not cover the lost phone, so enrolment also hands out ten single-use **recovery codes**, and a code is accepted anywhere a TOTP code is. Unlike the seed, a code *is* compared, so it is hashed like a token.

The small decisions are where the value is: matching forgives case and dashes, and the alphabet drops the characters people confuse, because these are read aloud and typed off paper; spending a code is the same statement that matches it, so two simultaneous sign-ins cannot both spend one; a spent row is kept rather than deleted, so "already used" stays distinguishable from "never issued"; re-issuing replaces the whole set, because a set on paper should be the whole truth about what opens the account; and revoking the second factor deletes the codes with it.

14.5 How long a session lasts

Two clocks, because they answer different attacks. An **idle** timeout limits an unattended desk; an **absolute** cap limits a stolen token that is being used, which never idles out. The shipped defaults are thirty minutes and eight hours — the least disruptive ends of OWASP's own bands — and `null` on either means no limit on that axis, spelled explicitly so that "I did not set this" and "I turned this off" cannot look the same.

Only a SESSION is governed. A machine token is idle by design, and idling one out is a silent outage, so API and worker tokens are exempt — and the parameter that says which a token is defaults to the exempt value, so a caller who forgets it mints a token that behaves as

tokens always did. The clocks are epoch columns rather than the text timestamps beside them, because a text `CURRENT_TIMESTAMP` formats differently on each dialect and a rule comparing those would be invisible on one and wrong on the other.

An instance sets the policy and a company may TIGHTEN it, never loosen it: the effective value is the stricter of the two per axis. That is deliberately the opposite of branding, where the company's document wins whole — branding is cosmetic, this is a control, and the instance owns the floor. Enforcement is in `resolve-token` and nowhere else, the one place a bearer becomes a principal; a lapsed session is revoked with a reason, so the token list can say why it ended and a lapsed session cannot be revived by using it.

The console counts down against the last REQUEST, not against pointer activity. The server measures requests, so a mouse-driven timer would cheerfully show a live session the server had already expired.

14.6 The console's policy

Every response carries a baseline set of headers, and the console carries a Content-Security-Policy that is same-origin for everything. **Its script source is now `'self'` and nothing else** — no `'unsafe-inline'`, which is the directive that lets an injected script tag execute, and no nonce either. The nonce was the first answer and is gone: it existed solely to authorize the console's own inline block, and once that block became files on disk it authorized nothing, so the policy is strictly narrower than the one the nonce earned. The baseline policy every *other* response carries still allows inline script, because a plugin's own bundle page may legitimately ship some and that page is not the console.

Earning that cost more than the policy line. A nonce cannot authorize an inline event handler, and the console was built from a hundred and forty-one of them. They are all delegated listeners now: a render writes a data attribute holding an index into a registry of closures, and one listener per event type dispatches to it. The call expressions stayed where they were readable, and their arguments are now real values instead of being escaped into a string and parsed back out — which also removed a class of quoting bug where a title containing an apostrophe could break its own button. Style attributes keep their allowance, and the figure behind that was wrong when somebody finally counted: 392 of them, of which exactly **five** interpolate anything at all — a rounded number, a percentage, two variable names and the funnel's theme. Removing the allowance means moving 387 static attributes to classes, which is why it is still declined; and the re-measurement also enumerated the thing that would have to go wrong first, since CSS injection needs HTML injection ahead of it. Of 1,499 interpolations across the console's nineteen files, 373 go through the escaper, 550 are a known-safe shape, and almost all of the rest touch no server-supplied string — because the delegated-handler change returns an *index* and keeps the value in a closure. No path to HTML injection was found, so the CSP allowance is defence in depth on top of a control that holds, and the thing to re-run when a renderer is added is the enumeration rather than the attribute count.

One handler sat inside a single-quoted string rather than a template literal, so its registry call never interpolated and the funnel's submit button shipped as dead text. No static check saw it; a browser test pressed the button and timed out. There are now static checks for both the inline handlers and that exact stranding, because the policy holds only while they hold.

14.7 What the model is not told

Everything above is about keeping a secret *at rest*. The other direction is a document leaving the process on its way to a model, and it has three parts.

The detectors are named, not written. A request to redact asks for classes — emails, telephone numbers, national identifiers, a dictionary of terms the caller supplies — and there is deliberately no way to supply a pattern. A pattern would be operator-authored and run against the text of a document the operator does not control, which is catastrophic backtracking with the operator's own configuration as the weapon, on the upload path. It is the same call that froze the funnel's validation vocabulary and the workflow binding sublanguage, and here it costs the caller nothing, because nobody wants to write an email pattern.

A token is stable inside one document and deliberately not across them. Inside, because that is the whole reason a span becomes a token rather than a black box — the model can see that one person appears three times. Across, never: a token that meant the same person everywhere would be a pseudonym, a pseudonym is a join key, and two redacted documents would then tell their reader they concern the same person. Text that already contains something token-shaped is *refused* rather than escaped, since rehydration would otherwise write a real name where the document had an identifier — the one failure here that invents data instead of losing it. Putting the values back is one pass with a lookup, never a replacement per entry, or the tenth name rewrites the first eight characters of the eleventh; a token the model invented is left verbatim and reported, because guessing the nearest would put a real name into an answer about somebody never mentioned.

The map is sealed whenever a key exists, *not* gated on the content switch whose default is off — a column holding "PERSON_1 is this person" for every redacted document needs that more than anything else in the schema — and **nothing serves it**. No route reads it, which is how "it never leaves the instance" is kept by construction rather than by validation. The same rule reaches the tool's own result: it carries the tokens and never the values, because a result lands in a step's stored output, the agent transcript and a console pane, which is three more copies than the sealed row has.

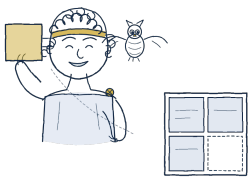
A step that redacts rehydrates before anything is stored, so the extraction a caller reads has the real values and the request that crossed the wire did not. Two asymmetries in that are the interesting part. The classifier redacts for the *model* and matches its own rules on the real text, because a rule is deterministic, local and never leaves the process, so matching it on tokens buys nothing and costs correctness. And the streaming endpoint *refuses* the option rather than ignoring it: a token can be split across two server-sent events, so putting values back means buffering the whole answer, which is the one thing a stream exists not to do — and half-rehydrated text, a real name beside a token with no way to tell which is which, is worse than a refusal.

Which executors may see a labelled document's unredacted text is a policy, and absence means off. A team labels a document through the ordinary metadata field it defines itself; a policy at the instance and company tiers then names which backends each label may reach. The tiers *tighten* where both speak. A label no tier mentions is refused, which is the opposite of how an undeclared capability is read elsewhere and is deliberate: the only way to reach that state is to remove a label from the policy while documents still carry it. A loopback backend is outside the policy entirely, so the ordinary single-box instance talking to a local model is unaffected. A typo in the executor list fails closed, so it is *reported* on the read rather than left to be discovered, and a refusal is audited with the label, the executor and the backend's host — never the text and never the document's key.

And there was no record of a model request at all. The quota ledger counts requests and can never answer what was sent, where it went, whose call it was, or whether it was refused. The table that answers those is defined by what is not in it: no prompt column, no reply column, no excerpt. Three paths leave this process and not one — a plain call, a stream, and a job row a remote worker will claim — so a log covering only the first would have been silent about exactly the two somebody would check. The prompt is recorded as a keyed digest and not a bare hash, because a bare hash of a name is the same digest on every machine in the world, which would make the table a confirmation oracle over the exact identifiers redaction exists to remove. With no key configured it is a plain hash and the row *says which*. And "this backend does not log content" is an assertion nothing can verify, so what is enforced is that somebody made it: a switch refuses a request to a backend that is not on this box until its operator has declared it, per executor, and unset the request still goes and the row reads "undeclared" — the gap visible rather than assumed.

14.8 Files to open

`domain/authz/secretbox.rkt`, `domain/authz/authz.rkt` (tokens, 2FA, recovery codes), `cli/telemachus-secrets.rkt`, `docs/ops/secrets-at-rest-runbook.md`, `test/secretbox-tests.rkt`, `test/console-tests.rkt`, `domain/repo/redact.rkt`, `domain/repo/redactions.rkt`, `domain/ai/sensitivity.rkt`, `domain/ai/requestlog.rkt`, `test/redact-tests.rkt`, `test/sensitivity-tests.rkt`, `test/dump-leak-tests.rkt`.



Chapter 15

Extending TMach

15.1 Four seams, and one prefix

A plugin is a directory with a manifest and an entry module, loaded at boot. It may fill four seams, and the whole extension contract is those four:

- **Tools** — `(provide tools)`. A capability the model may call. It registers through the same registry as the built-ins, so per-tool permissions and per-team activation apply without the plugin doing anything.
- **Workflows** — `(provide workflows)`, or spec files in a directory. Validated exactly as an API-published spec is, and materialized into a team on first lookup, because a plugin has no team at load time.
- **HTTP routes** — `(provide routes)`. Mounted at `/api/x/<plugin-id>/...`. The prefix is platform-fixed, so a plugin cannot shadow a core route or another plugin's; every route requires a bearer token and the permission it names is checked before the handler runs; and a malformed entry fails *that plugin's load* rather than a request an hour later. `args` carries the params, the query, the body and the request headers. A handler that returns a response sets its own status and headers, the same as a core handler, so a route can answer 409, 404 or 422 rather than folding every refusal into a 400.
- **Job kinds** — registered from `init!`, named `x.<plugin-id>.<name>`. A plugin kind is an ordinary job: the enqueuing team and user, the concurrency cap, quota admission, the org gate, cancellation and the lease all apply, and none of it is inherited from the plugin. A remote kind must supply a validator, since there is no in-process handler to be strict for it.

15.2 Where plugins are found, and what happens when one is not

The built-in directory is always searched; `TMACH_PLUGINS` adds more, as a `:`-separated list, and a literal `-` entry drops the built-ins for a deployment that means to ship only its own. It used to name the ONE directory to load, so adding a plugin of your own silently removed the document pipeline and every other shipped one — an instance that came up looking healthy with its workflows gone.

That shape — healthy-looking and quietly missing — is worth naming, because the loader had a second instance of it. A plugin that throws while loading is caught, logged and skipped, which is right: one bad plugin must not stop the server. But it was ONLY logged, one line among sixty, and the instance then served an API with that plugin's tools, workflows, routes and job kinds simply absent. Failures are kept now: a `failed` list beside the plugin listing, a warning block at boot that says how many and why, and a strict mode that refuses to start at all. Two plugins claiming one id is a failure too, rather than a silent shadow.

A related trap, since it produced exactly this: `raco make` does not reach a plugin's entry module, because the loader `dynamic-requires` it. A Racket upgrade therefore leaves stale bytecode under `plugins/<id>/compiled/` that fails to load — and before the change above, said so in one line nobody read.

15.3 Screens of your own

A plugin serves its own pages from two directories, and the difference between them is who may read them. `landing/` is public at `/beta/bundle/<id>/` and publicly cached — it is a marketing funnel a prospect is linked to. `bundle/` is authenticated at `/api/x/<id>/bundle/`, requires a bearer token, and is answered `private, no-store`. Customer screens belong in the second; before it existed there was only the first, and serving a signed-in screen set from it would have put customer pages behind a public cache.

Assets ship inside the bundle. The console's policy is same-origin, so a CDN font or script is blocked — deliberately.

Two things about that authenticated directory are worth knowing before you build on it. Its files are served from where the LOADER found the plugin, not from a fixed path under the checkout: a plugin loaded from elsewhere used to serve its tools and routes perfectly while every page it had came back 404. And a page there cannot simply be opened in a browser, because the token lives in the console's storage and a navigation carries no bearer — the smoke passed for months because `curl` sends a header a browser never will. Opening one means minting a short-lived TICKET with the token you do have; the first response sets it as a cookie scoped to that plugin's bundle path, so the page's own script and stylesheet follow without it trailing through every URL. Not a session cookie issued at sign-in: the JSON API keeps its no-cookie, no-CSRF-surface property, and this one reaches nothing but one plugin's static files.

15.4 Wearing the customer's colours

The branding document carries a *theme*: background, surface, ink, muted, brand, the ink that sits on the brand, a corner radius, a mode and a font. It is the same token vocabulary the onboarding funnel already used, so a palette is written once and worn by both, and it is per-organization for free, because a company's branding is one more document under the same key — a company on its own hostname is themed before anyone signs in.

Two rules keep it honest. An unknown token is refused rather than ignored, because a token that silently does nothing is how an integrator concludes the theming is broken. And contrast is *enforced* by the server, not merely warned about: WCAG AA for text, muted text, text on a panel and a button label, and a lower bar for the brand against its ground. This is the screen people sign in on, and an instance that themed its own sign-in link into invisibility would have no way back through the UI. The button's ground is a colour the console mixes rather than a token, so that mix is what gets checked — checking the brand itself would fail themes that

render perfectly and pass ones that do not — and which side of the palette counts as dark is measured, not read from the mode token.

15.5 What is not available

Stated plainly, so nobody designs around a hope: a plugin cannot add a tab to the core console — it serves its own screens instead; a plugin cannot add a feature flag of its own, or a permission, or a quota dimension, or a sealed column — each of those is a core vocabulary, and the role listing publishing a permission the server does not enforce is a promise nobody keeps; and there is no hot reload, so adding a plugin means a restart.

15.6 Files to open

`docs/integrators-guide.md`; `plugins/integrator-demo/`, the worked example — a tool, two routes, a job kind and a themed screen; `domain/agent/plugins.rkt`; `domain/branding/branding.rkt`; `docs/reference/sdk.md` and `docs/reference/plugins.md`.



Chapter 16

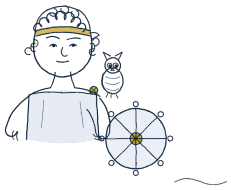
How the project tests

- **Unit suites** (`test/*-tests.rkt`) exercise `domain/` directly against a fresh database, on both dialects. Whole pipelines run through the real scheduler by draining its queue in the test process.
- **Smoke scripts** (`test/server-smoke.sh` and friends) boot a real server and assert over HTTP with `curl`. *Test the endpoints, not just the model*: the bug that actually bit the Localization Manager lived in the HTTP layer, where a query filter compared a string against symbol keys and silently fell back to its default.
- **The end-to-end gate** (`test/e2e/validate.sh`) drives the console in a headless browser, fails on any uncaught page error and any 5xx, and runs the whole document pipeline against the scripted mock model. It is the deploy gate; the screenshot tours do not assert and will photograph a broken page.
- **Mocks are servers.** `test/mock-llm.rkt` is a deterministic OpenAI-compatible model with a tool-call mode for the agent loop and a chat mode for the pipeline.
- **Verify on PostgreSQL** before calling anything done. Everything honours `DATABASE_URL`.
- **The gates in CI**: unit, smoke, multi-tenancy, the S3 endpoint against the real `aws` client, the localization gate (English required, other locales advisory), the documentation drift gate, the end-to-end gate, and the funnel's browser test.

A suite that can skip is a suite that can hide. The S3 smoke exits cleanly when the `aws` CLI is absent — so when the credential's secret became encrypted at rest, the path that decrypts it on every signed request went unexercised, because no developer box and no CI runner had the client. The client is in the development shell and installed in CI now, and the suite runs with the secret sealed, which is how a real deployment runs it. The same suite had never run outside the Nix shell, so it had never needed to set its own collection path; its first run in CI could not load a library and reported that the server never came up.

Some things only a browser can see. Converting the console's inline handlers left exactly one of them inside a quoted string rather than a template literal, so it rendered as literal text and the funnel's submit button did nothing. Every static check passed. A browser test pressed the button and timed out. Where a static check *is* possible, write it afterwards: the two invariants that conversion depends on are now pinned in a unit test that reads the console as a file.

Some habits the tests taught: never assert "newest first" on two rows created in the same second; kill a background server by PID, never by pattern (`pkill -f` matches its own command line); a test that creates documents must point the blob root at a temporary directory or it writes into the checkout.

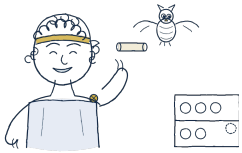


Chapter 17

Operating notes

- **Paths are anchored at definition.** The web server repoints the current directory at its own web root while it handles a request — inside the read-only Nix store on a packaged install. A relative path resolved lazily aims at the store. The blob root is absolute by construction, a unit test asserts it, and the server refuses to boot with a relative one. This shipped once: startup was healthy, every unit test passed, and the first document save failed with "Permission denied".
- **Quotas stall queues.** A workflow step is a scheduler job admitted only when the team is under its AI budget. With the default two thousand tokens a day, a bulk draft or a batch extraction stops after the first jobs and looks like a hang. Raise `ai.tokens.total` first; the Automations card shows the remaining budget for this reason.
- **Uploads above one megabyte need the listener's limit raised**, or the underlying web server drops the connection with no response at all.
- **The console caches its HTML at startup**; restart to pick up edits.
- **Multi-tenancy needs one restart** to set the flag; onboarding a company after that needs none.
- **PDF text extraction needs poppler-utils**; a missing extractor fails the indexing run deliberately, so that no PDF is silently unsearchable for months.
- **Decide about secrets at rest before you take a backup.** With no key set, a dump of the database carries every TOTP seed and S3 secret in the clear — a supported choice, and now a visible one. Adopting a key is one command and no downtime; keeping the key in the same backup as the database buys nothing. Losing it means re-enrolling every second factor and re-issuing every access key.
- **Upgrading the server upgrades the workers.** A pull worker must return the claim's fencing token with every heartbeat and result; one that does not gets a 409. The reference worker sends it, but a third-party worker has to be updated in step.
- **A theme can be refused.** The console's palette is validated and contrast-gated when it is written, so an operator who asks for an unreadable combination is told which pair and by how much, rather than discovering it on the sign-in screen.

The runbooks under `docs/ops/` cover the document repository, the workflow engine and multi-tenancy in operator terms.



Chapter 18

Contributing

- Read `CLAUDE.md` before starting; add to it when you learn something that cost you time. It is the project's memory.
- Keep SQL dialect-neutral and run the suites on both dialects.
- Every model-facing feature validates and refuses; every AI call is metered; every resource is checked through `can?`.
- Refuse loudly rather than degrade quietly. An unreadable reply, an unknown theme token, a secret that will not decrypt and a schema the model did not honour are all errors that name themselves — never an empty string, a dropped field or a silent default. Most of the bugs this project has had to hunt were something failing politely.
- Adding a route, a tool, a workflow or a permission changes the generated reference: regenerate and commit it in the same change.
- New user-facing strings go into the right home of the three, then through the extractor. English is required by the gate; other locales are coverage.
- Design first for anything with a policy fork: a short document under `docs/design/` with data shapes, a contract any backend could implement, and the decisions to confirm. The decision log is `docs/design/decisions.md`.
- Commit messages say what was verified and how. A slice is done when the unit suites, the smokes, the gate and `nix build` agree, on both databases.